11信息系统治理

IT治理

- IT治理基础
  - 驱动因素
    - 历史原因形成“信息孤岛”，系统集成难题无法解决；
    - 信息资源整合目标空泛，没有整合“信息孤岛”的措施，规划缺乏可操作性，尤其是缺少数据标准化建设方面的建设规划。
  - 内涵
    - 体现了治理层和最高管理层对信息相关活动的关注；
    - 为组织战略规划提供技术或控制方面的支持，以保证相关建设能够真正落实并贯彻组织业务战略和目标；
    - 确保信息系统应用有效、及时地满足需求，并获得期望的收益，增强组织的核心竞争力；
    - 是一种制度和机制，管理和制衡信息系统与业务战略匹配、信息系统建设投资、信息系统安全和信息系统绩效评价；
    - IT 治理的组成部分包括管理层、组织结构、制度、流程、人员、技术等多个方面，共同构建完善的IT 治理架构，达到数字战略和支持组织的目标。
  - 目标价值
    - 与业务目标一致
    - 有效利用信息与数据资源
    - 风险管理
  - 管理层次
    - 最高管理层
    - 执行管理层
    - 业务与服务执行层
- IT治理体系
  - 构成
    - IT 定位，IT 应用的期望行为与业务目标一致
    - IT 治理架构，业务和IT 在治理委员会中的构成、组织IT 与各分支机构的IT权责边界等
    - IT 治理内容，决策、投资、风险、绩效和管理等
    - IT 治理流程，统筹、评估、指导、监督
    - IT 治理效果（内外评价）
  - 关键决策
    - IT 原则
    - IT 架构
    - IT 基础设施
    - 业务应用需求
    - IT 投资和优先顺序
  - 体系框架
    - IT 战略目标
    - IT 治理组织
    - IT 治理机制
    - IT 治理域
    - IT 治理标准
    - IT 绩效目标
  - 核心内容
    - 本质
      - 实现IT的业务价值
      - IT风险的规避
    - 核心内容
      - 组织职责
      - 战略匹配
      - 资源管理
      - 价值交付
      - 风险管理
      - 绩效管理
  - 机制经验
    - 原则
      - 简单
      - 透明
      - 适合
    - 影响力高且具有挑战性的IT治理机制

表 11-2　影响力高且具有挑战性的 IT 治理机制

机制	目标	期望行为	不期望行为
执行层和高级管理委员会	对业务（包括 IT）的整体观念	整合 IT 的无缝管理	IT 被忽略
架构委员会	明确战略技术和标准是否被执行	业务驱动的 IT 决策制定	IT 限制和延迟
有 IT 人员参与的流程团队	有效地运用 IT 视角	端对端的流程管理	功能性技能的停滞和分散的 IT 基础设施
资金投资批准和预算	把 IT 看作另一种业务投资	对于不同投资类型的不同方法	分析瘫痪小项目，避开了正式批准
服务水平协议	对于 IT 服务的详细说明和衡量	专业的供应和需求	管理服务水平协议而不是业务需求
费用分摊机制	从业务中补偿 IT 成本	IT 的可靠应用	关于收费和歪曲的需求的争论
IT 业务价值的正式追踪	衡量 IT 投资，并通常运用平衡计分卡计算其对业务价值的贡献	使目标、利益和成本透明化	将 IT 同其他资产相分离，只关注资金流，而不关注价值

    - 最佳实践
      - IT指导委员会要吸纳有才干的业务经理，使之负责组织范围的IT治理决策，并在IT原则中加入严格的成本控制。谨慎管理组织的IT架构和业务架构，以降低业务成本。
      - 设计严格的架构例外处理流程，使昂贵的例外最小化，并可以从中不断学习。
      - 建立集中化的IT 团队，用以管理基础设施、架构和共享服务。
      - 应用连接IT投资和业务需求的流程，既可以增加透明度，又可以权衡中心和各运营部门或团队的需求。
      - 设计需要对IT投资进行集中协作和核准的IT投资流程。
      - 设计简单的费用分摊和服务水平协议机制，以明确分配IT开支。
- IT治理任务
  - 全局统筹
    - 制定满足可持续发展的IT 蓝图；
    - 实施科学决策、集约管理的策略，实现横向的业务集成和纵向的业务管控，通过内外部的监督，确保IT 与业务的一致性和适用性；
    - 建立适应内外部信息环境变化的待续改进和创新机制
  - 价值导向
    - 认可信息技术、信息系统和数据在组织中的价值；
    - 识别投资目录，并以相应的方式进行评估和管理；
    - 对关键指标进行设定和监督，并对变化和偏差做出及时回应；
    - 权衡实施成本与预期效益，并随组织内外部环境的变化及时调整。
  - 机制保障
    - 指导建立规范过程管理和痕迹管理，并向利益相关者公开质量设定举措；
    - 评审IT 管理体系的适宜性、充分性和有效性；
    - 审计IT 的完整性、有效性和合规性；
    - 监督由审计和管理评审提出的改进内容的实施。
  - 创新发展
    - 创造基于业务团队与IT 团队的深度沟通以及对内外部环境感知和学习的技术创新环境；
    - 确保技术发展、管理创新、模式革新的协调联动；
    - 对组织创新能力进行评估，并对关键创新要素进行分析和评价；
    - 通过促进和创新，有效抵御风险，并确保创新是组织文化的组成部分。
  - 文化助推
    - 建立与IT 发展相适应的组织文化发展策略；
    - 营造包括知识、技术、管理、情操在内的积极向上的文化氛围；
    - 根据组织内部环境的变化，评估并改进组织文化的管理。
- IT治理方法与标准
  - 信息技术服务标准（ITSS）
    - 通用要求
      - 作用
        - 建立组织的IT 治理体系，并实施自我评价；
        - 开展信息技术审计；
        - 研发、选择和评价IT 治理相关的软件或解决方案；
        - 第三方对组织的IT 治理能力进行评价。
      - 治理模型
        - 治理的内外部要求
        - 治理主体
        - 治理方法
        - 信息技术及其应用的管理体系
      - 治理框架
        - 顶层设计
        - 管理体系
        - 资源
    - 实施指南
      - 作用
        - 建立组织的IT 治理实施框架，明确实施方法和过程；
        - 组织内部开展IT 治理的实施；
        - IT 治理相关软件或解决方案实施落地的指导；
        - 第三方开展IT 治理评价的指导。
      - 实施框架
        - 实施环境
        - 实施过程
          - 统筹和规划
          - 构建和运行
          - 监督和评估
          - 改进和优化
        - 治理域
          - 顶层设计
            - 战略
            - 组织
            - 架构
          - 管理体系
            - 质量管理
            - 项目管理
            - 投资管理
            - 服务管理
            - 业务连续性管理
            - 信息安全管理
            - 风险管理
            - 供方管理
            - 资产管理
            - 其他管理
          - 资源
            - 基础设施
            - 应用系统
            - 数据
  - 信息和技术治理框架（COBIT ）
    - 治理和管理目标
      - 管理目标
        - 调整、规划和组织(APO) 领域针对IT 的整体组织、战略和支持活动；
        - 内部构建、外部采购和实施(BAI) 领域针对IT 解决方案的定义、采购和实施以及它们到业务流程的整合；
        - 交付、服务和支持(DSS) 领域针对IT 服务的运营交付和支持，包括安全；
        - 监控、评价和评估(MEA) 领域针对IT 的性能监控及其与内部性能目标、内部控制目标和外部要求的一致程度。
      - 治理系统的组件
        - 流程
        - 组织结构
        - 原则、政策和程序
        - 信息
        - 文化、道德和行为
        - 人员、技能和胜任能力
        - 服务、基础设施和应用程序
    - 信息和技术治理解决方案的设计
      - 设计因素
        - 组织战略、组织目标、风险概况、IT 相关问题、威胁环境、合规性要求、IT 角色、IT 采购模式、IT 实施方法、技术采用战略、组织规模和未来因素。
      - 设计流程
        - 了解组织环境和战略，需要了解组织战略、目标、风险概况和单签；
        - 确定治理系统的初步范围；
        - 优化治理系统的范围；
        - 最终确定治理系统的设计。
  - IT 治理国际标准（ISO38500）
    - 内容
      - ①责任。②战略。③收购。④性能。⑤一致性。⑥人的行为。
    - 任务
      - 评估。治理机构应审查和判断当前和未来的IT 使用，包括计划、建议和供应安排（无论是内部、外部或两者兼有）。在评估IT 的使用时，治理机构应考虑作用于组织的外部或内部压力，还应考虑当前和未来的业务需要。
      - 指导。治理机构应负责战略和政策的编制和执行。
      - 监督。治理机构应通过适当的测量系统来监测IT 的表现。治理机构还应确保IT 符合外部义务（法规、立法、普通法、合同）和内部工作惯例等。

IT审计

- IT审计基础
  - 定义
    - 根据IT 审计标准的要求，对信息系统及相关的IT 内部控制和流程进行检查、评价，并发表审计意见。
  - 目的
    - 通过开展IT审计工作，了解组织IT系统与IT活动的总体状况，对组织是否实现IT目标进行审查和评价，充分识别与评估相关IT风险，提出评价意见及改进建议，促进组织实现IT目标。
    - 组织的IT目标
      - 组织的IT 战略应与业务战略保持一致；
      - 保护信息资产的安全及数据的完整、可靠、有效；
      - 提高信息系统的安全性、可靠性及有效性；
      - 合理保证信息系统及其运用符合有关法律、法规及标准等的要求。
  - 范围
    - 总体范围
    - 组织范围
    - 物理范围
    - 逻辑范围
    - 其他相关内容
  - 人员
    - 职业道德、知识、技能、资格和经验、专业胜任能力、外部专家服务等。
  - 风险
    - 固有风险、控制风险、检查风险
- IT审计方法与技术
  - 方法
    - 访谈法：通过交谈了解信息。分为结构型和非结构型访谈。
    - 调查法：通过书面或口头回答问题的方式收集资料，分析得到结论。
    - 检查法：对记录、文件或资产进行审查。从技术层面上可分为审阅法、核对法、复算法和分析法。
    - 观察法：到被审计单位进行实地察看来证实审计事项。适用于正在进行中的审计事项。
    - 测试法：过测试来评估程序的质量。主要包括黑盒法和白盒法。
    - 程序代码检查法：对被审程序的指令逐条加以审查。
  - 技术
    - 风险评估技术
      - 风险识别技术，用以识别可能影响目标的不确定性，包括德尔菲法、头脑风暴法、检查表法、SWOT技术及图解技术等。
      - 风险分析技术，是对风险影响和后果进行评价和估量，包括定性分析和定晕分析。
      - 风险评价技术，通过相应的指标体系和评价标准，对风险程度进行划分，揭示影响成败的关键风险因素，包括单因素风险评价和总体风险评价。
      - 风险应对技术，是IT技术体系中为特定风险制定的应对技术方案，包括云计算、冗余链路、冗余资源、系统弹性伸缩、两地三中心灾备、业务熔断限流等。
    - 审计抽样技术
      - 统计抽样：采用客观的方法来确定样本量和样本抽取标准。常用的统计抽样方法有属性抽样和变量抽样。
      - 非统计抽样：常指判断抽样，即采用审计人员判断来确定抽样方法、样本量及抽样标准。
    - 计算机辅助审计技术（CAAT）
    - 大数据审计技术
  - 证据
    - 审计证据是指由审计机构和审计人员获取，用于确定所审计实体或数据是否遵循既定标准或目标，形成审计结论的证明材料。
    - 审计证据的特性有：充分性、客观性、相关性、可靠性、合法性。
  - 底稿
    - 审计人员对制订的审计计划、实施的审计程序、获取的相关审计证据，以及得出的审计结论做出的记录。
    - 一般分为综合类工作底稿、业务类工作底稿和备查类工作底稿。
- IT审计流程
  - 审计准备阶段。从计划开始，到发出审计通知书为止的期间。包括： 明确审计目的及任务；组建审计项目组；搜集相关信息；编制审计计划等。
  - 审计实施阶段。审计人员将项目审计计划付诸实施的期间。包括： 深入调查并调整审计计划； 了解并初步评估IT内部控制；进行符合性测试； 进行实质性测试等。
  - 审计终结阶段。整理审计工作底稿、总结审计工作、编写审计报告、做出审计结论的期间。包括：整理与复核审计工作底稿； 整理审计证据；评价相关IT 控制目标的实现；判断并报告审计发现；沟通审计结果； 出具审计报告；归档管理等。
  - 后续审计阶段。在审计报告发出后的一定时间内，检查被审计单位对审计问题和建议是否已经采取了适当的纠正措施，并取得预期效果的跟踪审计。后续审计并不是一次新的审计，而是前一次审计的有机组成部分。实施后续审计，可不必遵守审计流程的每一过程和要求，但必须依法依规进行检查、调查，收集审计证据，写出后续审计报告。
- IT审计内容
  - IT内部控制审计
  - IT专项审计
    - 信息系统生命周期审计
    - 信息系统开发过程审计
    - 信息系统运行维护审计
    - 网络与信息安全审计
    - 信息系统项目审计
    - 数据审计

至立学院系规VIP用户专用资料